Report 2 – Remediation

Azioni di rimedio sulle vulnerabilità critiche di Metasploitable2

1. Introduzione

Studente	Squicciarino Donato
Esercizio	Esercizio finale W12D4
Corso	Epicode – Cybersecurity & Ethical Hacker
Documento	Report 2 di 3 – RemediationMeta
Target	Metasploitable2 (192.168.51.101)
Strumenti	Kali Linux (nmap, netcat, vncviewer) e console della macchina Metasploitable2
Data degli interventi	4 ottobre 2026

Questo report documenta passo per passo le azioni di rimedio applicate alle quattro vulnerabilità critiche selezionate nel Report 1 (ScansioneInizio). Per ciascuna vulnerabilità sono riportati: il problema, la prova iniziale, l'individuazione della causa, il rimedio con la spiegazione di ogni comando e la verifica finale. Le modifiche sono state eseguite come utente root dalla console della macchina Metasploitable2 (accesso con msfadmin e poi sudo su), mentre le prove di raggiungibilità sono state eseguite da Kali Linux. Per i file di configurazione modificati è stata creata prima una copia di backup con estensione .bak.

#	Vulnerabilità	Porta	Azione di rimedio	Esito
1	Bind Shell Backdoor Detection	1524/tcp	Riga ingreslock disattivata in /etc/inetd.conf e riavvio di xinetd	Porta chiusa
2	VNC Server 'password' Password	5900/tcp	Nuova password con vncpasswd e riavvio di Xtightvnc	Vecchia password rifiutata
3	SSL Version 2 and 3 Protocol Detection	25/tcp e 5432/tcp	Postfix: TLS disattivato. PostgreSQL: ssl = false	Nessun protocollo SSL/TLS offerto
4	Apache Tomcat AJP (Ghostcat)	8009/tcp	Regola firewall iptables (DROP, con eccezione per il loopback)	Porta filtered

2. Stato iniziale dei servizi

Prima di intervenire è stata eseguita una scansione mirata con nmap sulle cinque porte coinvolte, per avere una prova di partenza confrontabile con quella finale.

`nmap -sV -p 25,1524,5432,5900,8009 192.168.51.101`

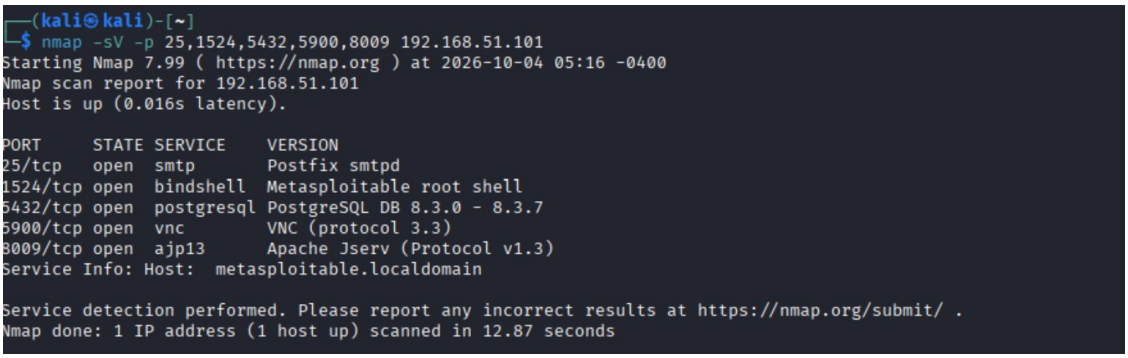


Figura 1 – Scansione nmap iniziale

Tutte e cinque le porte risultano aperte. La porta 1524 viene riconosciuta da nmap come bindshell ("Metasploitable root shell"), un'indicazione già evidente della gravità del problema. Sulla 8009 risponde il connettore AJP di Apache Tomcat (ajp13).

3. Remediation 1 – Bind Shell Backdoor (porta 1524)

3.1 Il problema

Sulla porta 1524/tcp è in ascolto una shell che non richiede alcuna autenticazione (plugin Nessus 51988, CVSS 9.8). Chiunque raggiunga la porta ottiene una shell con privilegi di root.

3.2 Prova iniziale

`nc 192.168.51.101 1524` – poi, nella shell ottenuta: `whoami`, `id`, `hostname`, `uname -a`



Figura 2 – Shell root ottenuta da Kali con un solo comando, senza alcuna autenticazione

Il comando netcat apre direttamente una shell: whoami restituisce root e id mostra uid=0(root). Il comando uname -a indica un kernel Linux 2.6.24 compilato nel 2008, a conferma dell'obsolescenza del sistema. In pratica un qualsiasi computer della rete ottiene il controllo completo della macchina con un solo comando.

3.3 Individuazione della causa

`grep -n ingreslock /etc/inetd.conf` e `ps aux | grep inetd`

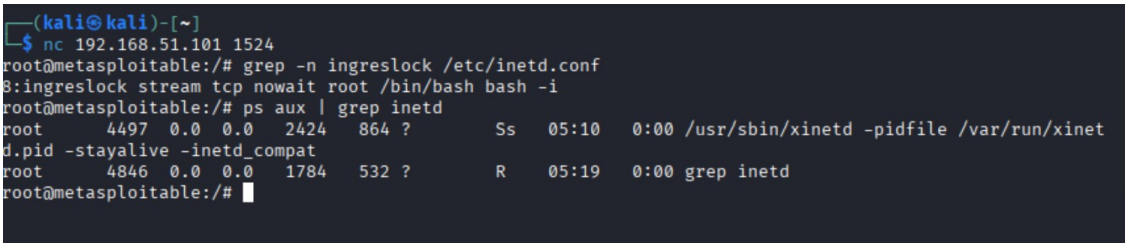


Figura 3 – Riga 8 di /etc/inetd.conf e processo xinetd in esecuzione

La riga 8 del file `/etc/inetd.conf` è `ingreslock stream tcp nowait root /bin/bash bash -i`. Significa che per ogni connessione al servizio ingreslock (porta 1524) viene avviata una shell interattiva (/bin/bash) con i privilegi dell'utente root. Non c'è quindi un programma malevolo da cercare: la backdoor è una riga di configurazione. Il secondo comando mostra che il processo in esecuzione è `/usr/sbin/xinetd` con l'opzione `-inetd_compat`: xinetd è il super-server della macchina e, in modalità compatibile, legge anche il vecchio file inetd.conf.

3.4 Rimedio

1. **Backup e modifica.** Prima si è salvata una copia del file (`cp /etc/inetd.conf /etc/inetd.conf.bak`), poi la riga è stata commentata con `sed -i 's/^ingreslock/#ingreslock/' /etc/inetd.conf`. Si commenta invece di cancellare perché la modifica resta documentata e reversibile. Il comando grep successivo mostra la riga con il simbolo # davanti.
2. **Primo tentativo di riavvio.** È stato eseguito `/etc/init.d/openbsd-inetd restart`, ma il comando netstat ha mostrato la porta ancora in ascolto (`0.0.0.0:1524 LISTEN 4497/xinetd`). Il servizio riavviato non era quello che gestisce la porta: xinetd manteneva in memoria la vecchia configurazione.
3. **Riavvio corretto.** Individuato il servizio corretto, è stato eseguito `/etc/init.d/xinetd restart`. Il riavvio è necessario perché xinetd legge la configurazione solo all'avvio.



Figura 4 – Riga commentata, ma porta ancora in ascolto con il vecchio processo xinetd (PID 4497)

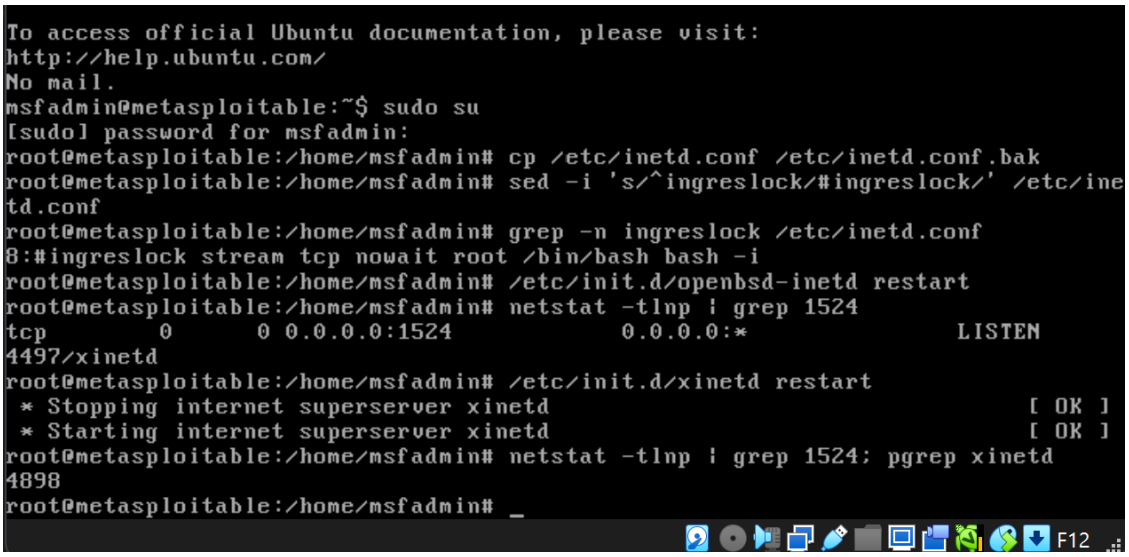


Figura 5 – Riavvio corretto di xinetd: nessun output da netstat sulla 1524 e nuovo PID (4898)

Dopo il riavvio corretto il comando netstat non restituisce più alcuna riga per la porta 1524, e pgrep mostra un nuovo PID (4898) diverso dal precedente (4497): è la prova che xinetd è stato riavviato e ha riletto la configurazione.

3.5 Verifica

```
nc -v 192.168.51.101 1524
```

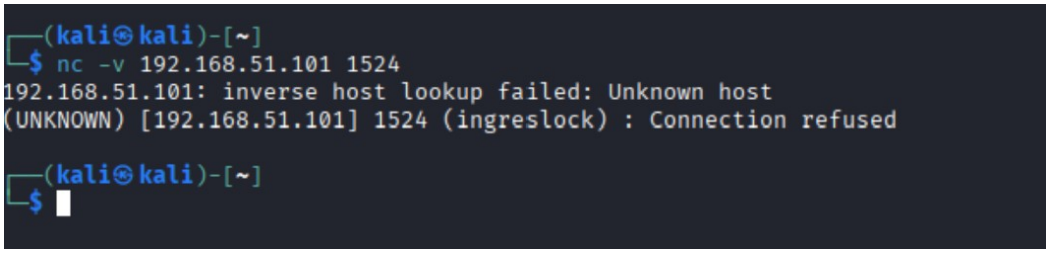


Figura 6 – Da Kali la connessione alla porta 1524 viene rifiutata

Lo stesso comando che prima apriva una shell root ora risponde "Connection refused": la backdoor non è più raggiungibile. La riga "inverse host lookup failed" è solo un avviso di netcat sulla risoluzione del nome e non influisce sul test.

4. Remediation 2 – VNC con password debole (porta 5900)

4.1 Il problema

Il server VNC in ascolto sulla porta 5900/tcp è protetto dalla password "password" (plugin Nessus 61708, CVSS 10.0). Nessus è riuscito ad autenticarsi con questa password, che è un account di default.

4.2 Prova iniziale

```
vncviewer 192.168.51.101:5900
```

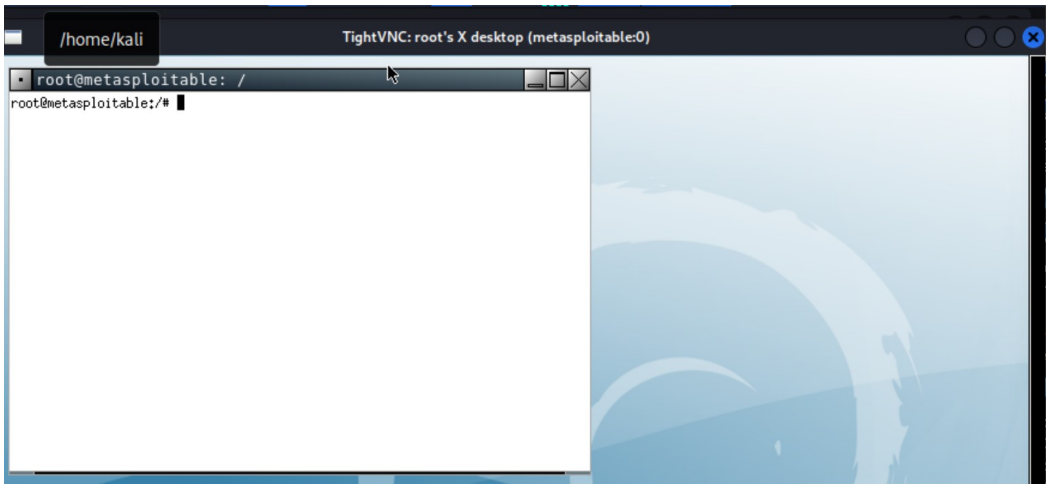


Figura 7 – Accesso al desktop remoto di root con la password di default

Con la password "password" si apre il desktop remoto dell'utente root (titolo della finestra: TightVNC: root's X desktop), con un terminale già in esecuzione come root. Un attaccante ottiene così il controllo completo della macchina.

4.3 Individuazione della causa

`ps aux | grep -i vnc`

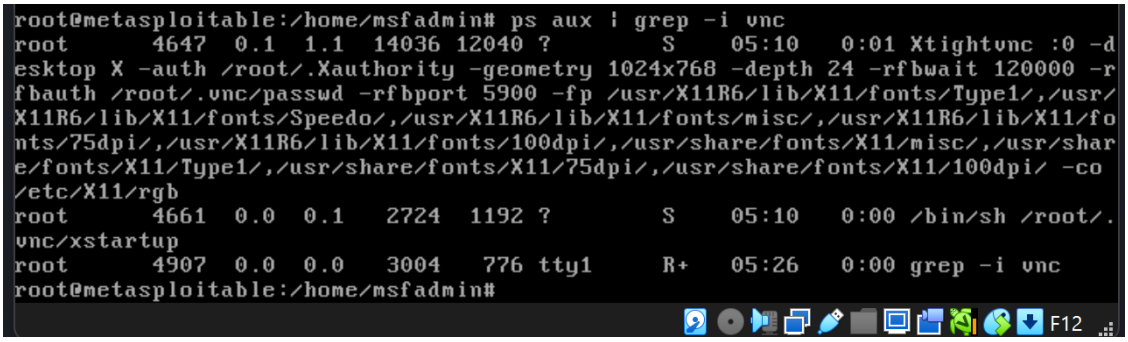


Figura 8 – Il server Xtightvnc gira come root e legge la password da /root/.vnc/passwd

Il processo `Xtightvnc :0` (PID 4647) gira come root e usa il parametro `-rfbauth /root/.vnc/passwd`: la password è memorizzata nel file `/root/.vnc/passwd` e il servizio la carica solo all'avvio. Il parametro `-rfbport 5900` conferma la porta esposta. Per risolvere bisogna quindi sostituire il file e riavviare il processo.

4.4 Rimedio

1. **Nuova password.** `export HOME=/root` e poi `vncpasswd /root/.vnc/passwd`. Il percorso del file è indicato in modo esplicito perché con sudo su la variabile HOME può puntare ancora alla cartella di msfadmin, e la password verrebbe scritta nel file sbagliato. È stata inserita una password robusta e alla domanda sulla password di sola visualizzazione è stato risposto n, in modo da avere un'unica password. Il messaggio "password truncated to the length of 8" è normale: il protocollo VNC usa soltanto i primi 8 caratteri.
2. **Riavvio del servizio.** `vncserver -kill :0` ferma il processo attivo (PID 4647) e `vncserver :0` lo riavvia. Il riavvio è necessario perché il processo in esecuzione aveva già caricato la vecchia password.
3. **Controllo.** `netstat -tlnp | grep 5900; pgrep Xtightvnc` mostra la porta 5900 di nuovo in ascolto con un nuovo PID (4927), diverso dal precedente.

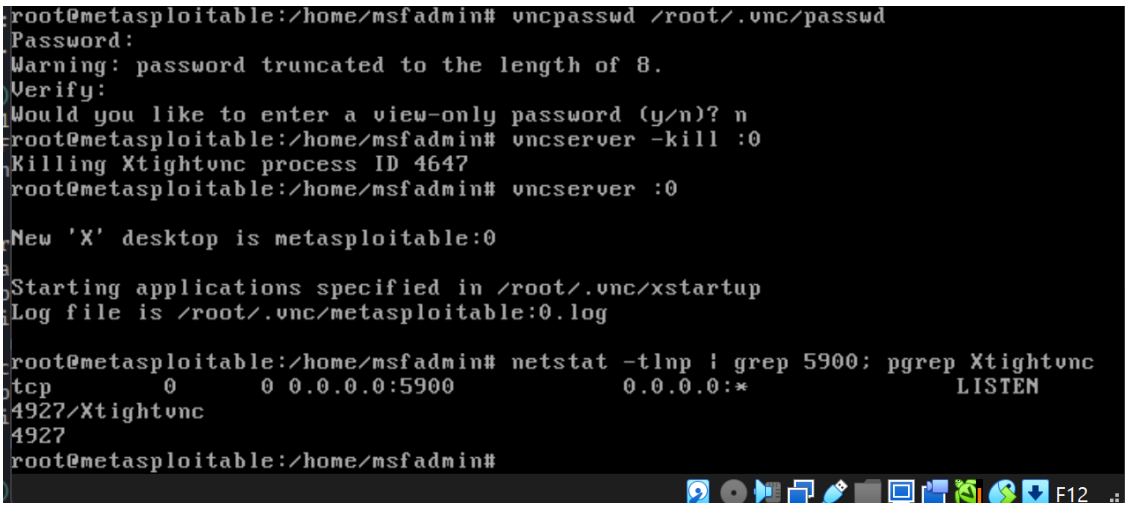


Figura 9 – Cambio password, riavvio di Xtightvnc e nuovo PID (4927) in ascolto sulla 5900

4.5 Verifica

La stessa connessione provata all'inizio è stata ripetuta due volte da Kali: prima con la vecchia password e poi con quella nuova.

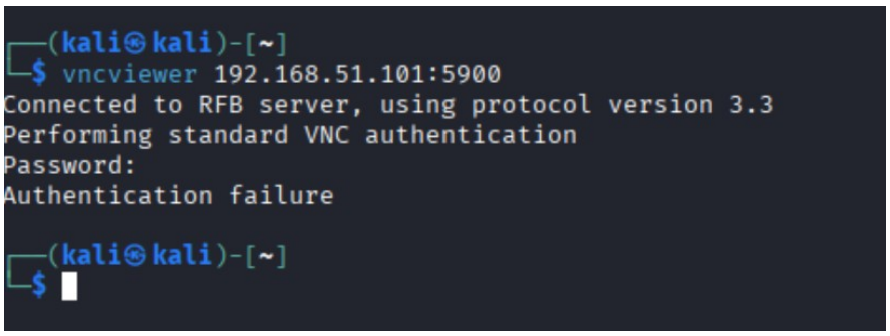


Figura 10 – Con la vecchia password l'autenticazione fallisce (Authentication failure)

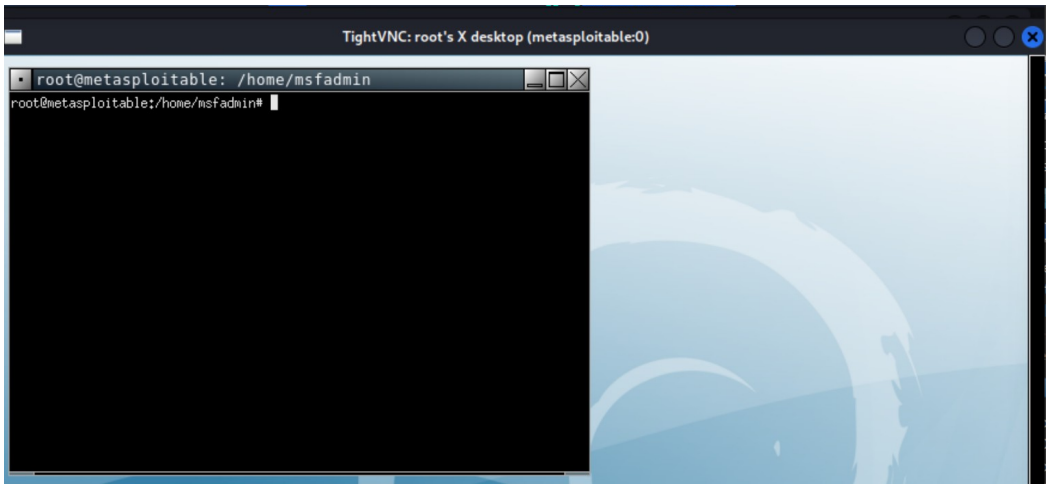


Figura 11 – Con la nuova password l'accesso funziona: il servizio è operativo ma protetto

L'esito dimostra che la password di default non è più accettata e che il servizio continua a funzionare con le nuove credenziali.

5. Remediation 3 – SSL versione 2 e 3 (porte 25 e 5432)

5.1 Il problema

Il plugin Nessus 20007 (CVSS 9.8) segnala che due servizi accettano connessioni cifrate con protocolli obsoleti: SSLv2 sul servizio SMTP (porta 25/tcp) e SSLv3 su PostgreSQL (porta 5432/tcp). SSL 2.0 e 3.0 hanno difetti crittografici noti (ad esempio POODLE, CVE-2014-3566) che permettono attacchi di downgrade e la decifrazione del traffico. Poiché non si possono correggere, vanno disabilitati.

5.2 Postfix (porta 25)

Prova iniziale

`nmap --script ssl-enum-ciphers,sslv2 -p 25 192.168.51.101`

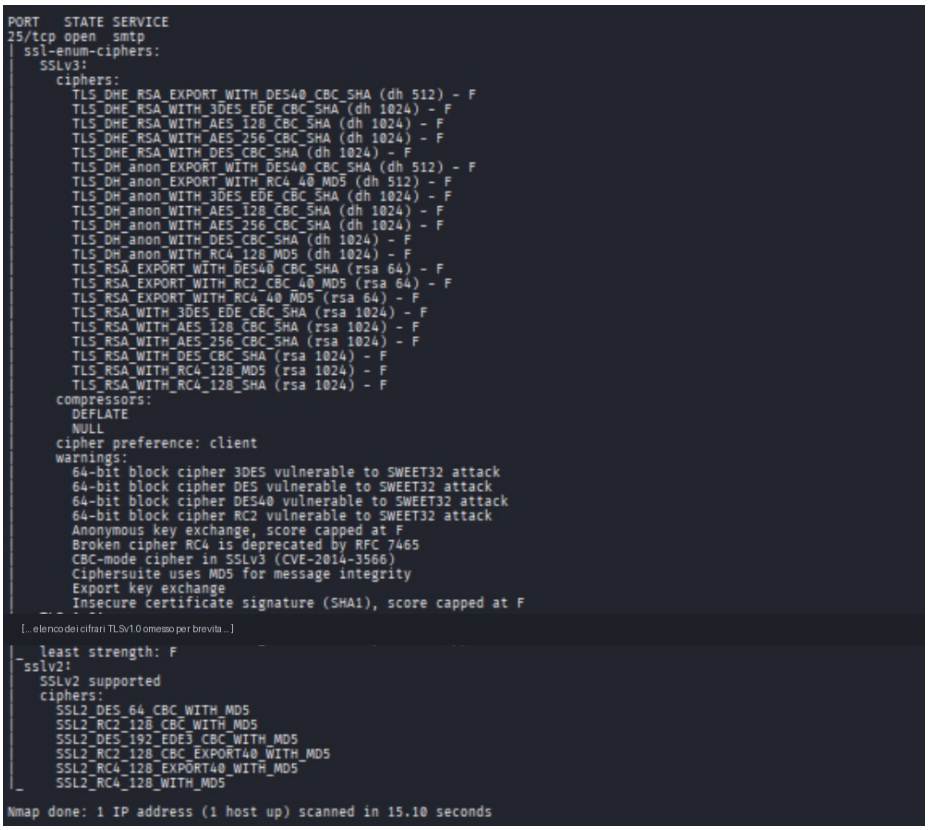


Figura 12 – La porta 25 accetta SSLv3, TLSv1.0 e SSLv2 con cifrari deboli (voto F)

Lo script di nmap elenca SSLv3, TLSv1.0 e SSLv2. Compaiono cifrari export a 40 bit, DES e 3DES (vulnerabili a SWEET32), RC4 (deprecato dalla RFC 7465), scambio di chiavi anonimo, firma MD5 e un certificato firmato con SHA1. Tutti i cifrari ricevono il voto F (least strength: F) e non è disponibile nessuna versione TLS moderna.

Individuazione della causa

`postconf mail_version` e `postconf -n | grep -i tls`

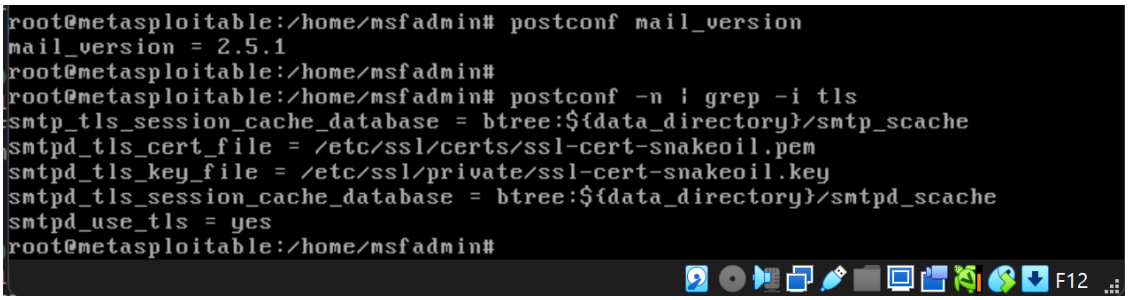


Figura 13 – Postfix 2.5.1 con smtpd_use_tls = yes

La versione di Postfix è la 2.5.1 e il parametro `smtpd_use_tls = yes` indica che il server offre la cifratura (STARTTLS) ai client. I parametri che permettono di escludere SSLv2 e SSLv3 (`smtpd_tls_protocols`) esistono solo dalla versione 2.6, e `smtpd_tls_mandatory_protocols` non si applica alla cifratura opportunistica, quella rilevata da Nessus. Con questa versione non è quindi possibile tenere solo i protocolli sicuri: l'unica azione disponibile è non offrire più la cifratura.

Rimedio

`cp /etc/postfix/main.cf /etc/postfix/main.cf.bak` crea il backup; `postconf -e 'smtpd_use_tls = no'` modifica il file main.cf senza aprire un editor; `/etc/init.d/postfix restart` fa rileggere la configurazione.

```
root@metasploitable:/home/msfadmin# postconf mail_version
mail_version = 2.5.1
root@metasploitable:/home/msfadmin#
root@metasploitable:/home/msfadmin# postconf -n | grep -i tls
smtp_tls_session_cache_database = btree:${data_directory}/smtp_scache
smtpd_tls_cert_file = /etc/ssl/certs/ssl-cert-snakeoil.pem
smtpd_tls_key_file = /etc/ssl/private/ssl-cert-snakeoil.key
smtpd_tls_session_cache_database = btree:${data_directory}/smtpd_scache
smtpd_use_tls = yes
root@metasploitable:/home/msfadmin# cp /etc/postfix/main.cf /etc/postfix/main.cf
.bak
root@metasploitable:/home/msfadmin# postconf -e 'smtpd_use_tls = no' 'smtp_tls_s
ecurity_level = none'
root@metasploitable:/home/msfadmin# /etc/init.d/postfix restart
 * Stopping Postfix Mail Transport Agent postfix                      [ OK ]
 * Starting Postfix Mail Transport Agent postfix                      [ OK ]
root@metasploitable:/home/msfadmin# postconf -n | grep -i tls
smtp_tls_security_level = none
smtp_tls_session_cache_database = btree:${data_directory}/smtp_scache
smtpd_tls_cert_file = /etc/ssl/certs/ssl-cert-snakeoil.pem
smtpd_tls_key_file = /etc/ssl/private/ssl-cert-snakeoil.key
smtpd_tls_session_cache_database = btree:${data_directory}/smtpd_scache
smtpd_use_tls = no
root@metasploitable:/home/msfadmin#
```

Figura 14 – Backup, modifica con postconf -e e riavvio di Postfix

Nel primo tentativo il secondo parametro è stato scritto per errore come `smtp_tls_security_level` (senza la "d"), che riguarda la posta in uscita e non il server che riceve. L'errore è stato individuato nel controllo con postconf -n. Si è quindi impostato il parametro corretto `smtpd_tls_security_level = none` e la riga errata è stata rimossa da main.cf con sed, perché l'opzione postconf -X non è supportata da Postfix 2.5.1.

```
root@metasploitable:/home/msfadmin# postconf -X smtp_tls_security_level
postconf: invalid option -- X
postconf: fatal: usage: postconf [-a (server SASL types)] [-A (client SASL types
)] [-b (bounce templates)] [-c config_dir] [-d (defaults)] [-e (edit)] [-h (no n
ames)] [-l (lock types)] [-m (map types)] [-n (non-defaults)] [-v] [name...]
root@metasploitable:/home/msfadmin# postconf -e 'smtpd_tls_security_level =none'
root@metasploitable:/home/msfadmin# /etc/init.d/postfix restart
 * Stopping Postfix Mail Transport Agent postfix                      [ OK ]
 * Starting Postfix Mail Transport Agent postfix                      [ OK ]
root@metasploitable:/home/msfadmin# postconf -n | grep -i tls
smtp_tls_security_level = none
smtp_tls_session_cache_database = btree:${data_directory}/smtp_scache
smtpd_tls_cert_file = /etc/ssl/certs/ssl-cert-snakeoil.pem
smtpd_tls_key_file = /etc/ssl/private/ssl-cert-snakeoil.key
smtpd_tls_security_level = none
smtpd_tls_session_cache_database = btree:${data_directory}/smtpd_scache
smtpd_use_tls = no
root@metasploitable:/home/msfadmin#
                                                                    F12
```

Figura 15 – Impostazione di smtpd_tls_security_level = none (l'opzione -X non esiste in Postfix 2.5.1)

```
root@metasploitable:/home/msfadmin# postconf -n | grep -i tls
smtp_tls_session_cache_database = btree:${data_directory}/smtp_scache
smtpd_tls_cert_file = /etc/ssl/certs/ssl-cert-snakeoil.pem
smtpd_tls_key_file = /etc/ssl/private/ssl-cert-snakeoil.key
smtpd_tls_security_level = none
smtpd_tls_session_cache_database = btree:${data_directory}/smtpd_scache
smtpd_use_tls = no
root@metasploitable:/home/msfadmin# _
                                                                    F12
```

Figura 16 – Configurazione finale: smtpd_use_tls = no e smtpd_tls_security_level = none

Verifica

`nmap --script ssl-enum-ciphers,sslv2 -p 25 192.168.51.101` e poi `nc 192.168.51.101 25` seguito da `EHLO test`



Figura 17 – Nessun protocollo SSL/TLS elencato e nessuna estensione STARTTLS nella risposta di Postfix

La porta 25 resta aperta e Postfix risponde, ma nmap non elenca più alcun protocollo SSL/TLS e, tra le estensioni dichiarate dal server dopo il comando EHLO, STARTTLS non compare più. Nessun client può quindi negoziare SSLv2 o SSLv3.

5.3 PostgreSQL (porta 5432)

Prova iniziale

`nmap --script ssl-enum-ciphers,sslv2 -p 5432 192.168.51.101`

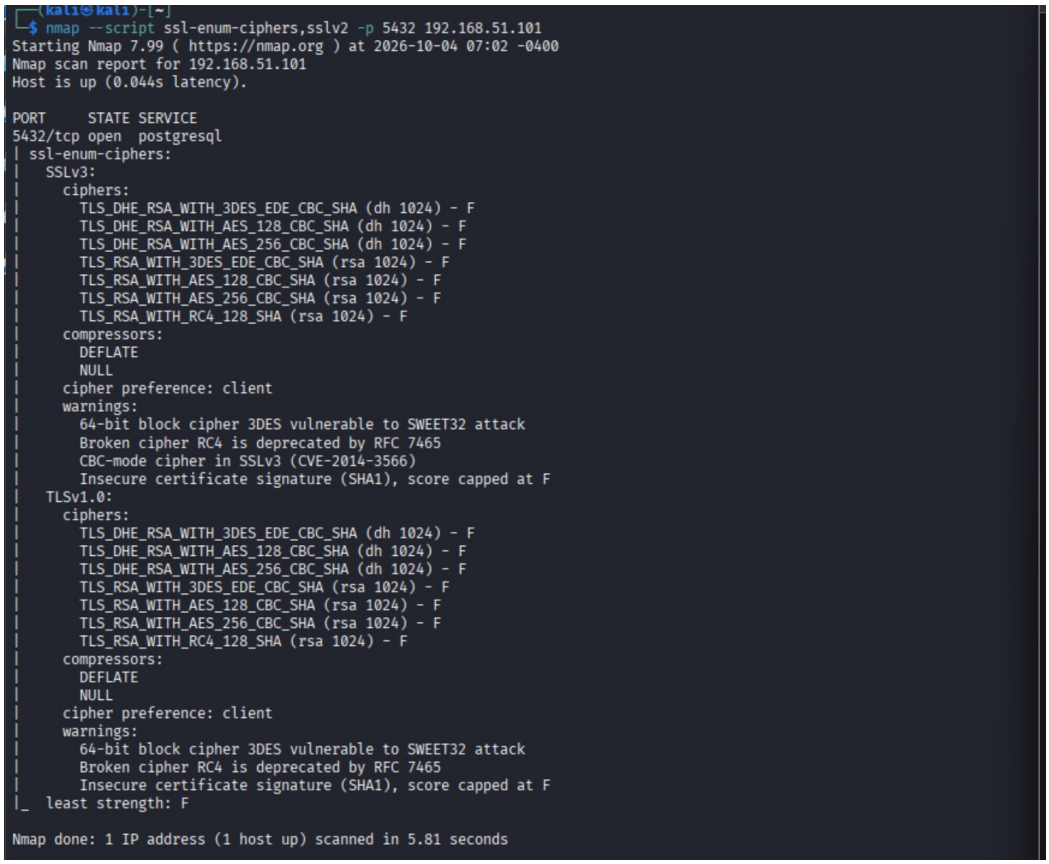


Figura 18 – La porta 5432 accetta SSLv3 e TLSv1.0 con cifrari deboli (voto F)

PostgreSQL accetta SSLv3, con l'avviso CBC-mode cipher in SSLv3 (CVE-2014-3566, cioè

POODLE), e TLSv1.0, con cifrari 3DES e RC4 e un certificato firmato con SHA1. Tutti i cifrari hanno voto F.

Rimedio

`grep -n "^ssl" /etc/postgresql/8.3/main/postgresql.conf` mostra la riga 76, `ssl = true`. Dopo il backup del file, `sed -i 's/^ssl = true/ssl = false/'` disattiva il supporto SSL, e il riavvio con `/etc/init.d/postgresql-8.3 restart` fa rileggere la configurazione (il file stesso indica "change requires restart").



Figura 19 – Da ssl = true a ssl = false con backup e riavvio di PostgreSQL 8.3

PostgreSQL 8.3 non permette di scegliere le versioni del protocollo: o offre SSL, con tutte le versioni obsolete incluse, oppure non lo offre. Per questo motivo la scelta è stata disattivarlo.

Verifica

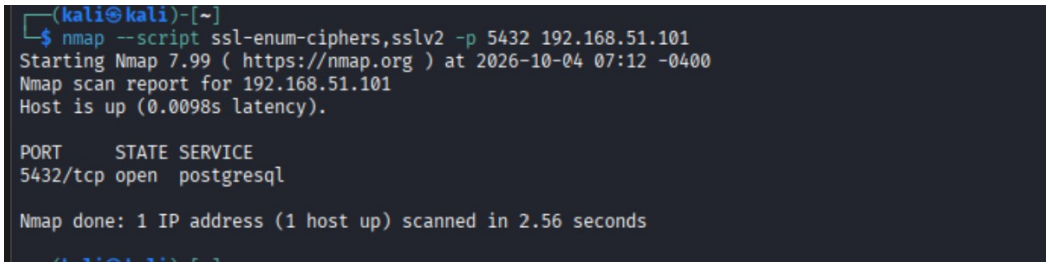


Figura 20 – Dopo la modifica nmap non elenca più alcun protocollo SSL/TLS sulla porta 5432

La porta 5432 risulta ancora aperta, quindi il database è raggiungibile, ma non offre più alcun protocollo SSL/TLS.

Compromesso da tenere presente

Disattivare la cifratura elimina i protocolli deboli, ma il traffico SMTP e quello verso il database ora viaggia senza cifratura. Con versioni così vecchie di Postfix e PostgreSQL non è possibile attivare TLS moderno: la soluzione definitiva è aggiornare i software e OpenSSL e configurare TLS 1.2 o superiore.

6. Remediation 4 – Apache Tomcat AJP "Ghostcat" (porta 8009)

6.1 Il problema

Il connettore AJP di Apache Tomcat è raggiungibile sulla porta 8009/tcp (plugin Nessus 134862, CVSS 9.8, CVE-2020-1938). AJP è un protocollo pensato per la comunicazione interna tra un web server e Tomcat e si fida di chi gli parla. Per questo la porta non dovrebbe essere visibile dalla rete. Come rimedio è stata scelta una regola firewall con iptables.

6.2 Rimedio con iptables

1. **Stato iniziale.** `iptables -L -n --line-numbers` mostra le catene INPUT, FORWARD e OUTPUT vuote, con policy ACCEPT: nessun filtro è attivo.
2. **Blocco della porta.** `iptables -I INPUT -p tcp --dport 8009 -j DROP` inserisce in

cima alla catena INPUT una regola che scarta i pacchetti TCP diretti alla porta 8009. L'opzione -I inserisce la regola all'inizio perché iptables legge la catena dall'alto e si ferma alla prima regola che corrisponde. DROP scarta i pacchetti senza rispondere, quindi dall'esterno la porta appare filtrata e non chiusa.

3. **Eccezione per il traffico locale.** `iptables -I INPUT -p tcp --dport 8009 -i lo -j ACCEPT` permette il traffico che arriva dall'interfaccia di loopback (lo), cioè dalla macchina stessa. Inserita per ultima, finisce sopra il DROP e viene valutata per prima.

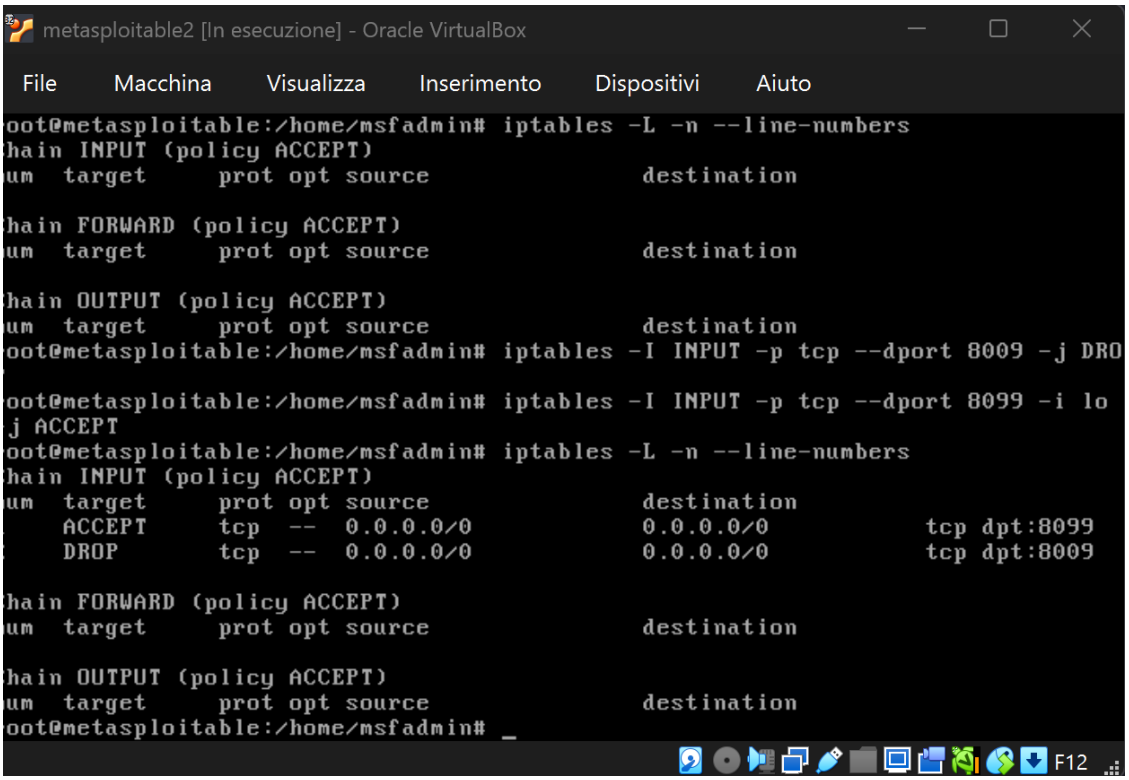


Figura 21 – Catene iniziali vuote e inserimento delle regole (la seconda con la porta 8099 per errore)

Nel primo inserimento della regola ACCEPT è stata digitata per errore la porta 8099 al posto della 8009: l'errore è visibile nell'elenco, dove la prima regola riguarda `dpt:8099`. La regola sbagliata è stata eliminata con `iptables -D INPUT 1` ed è stata reinserita con la porta corretta.

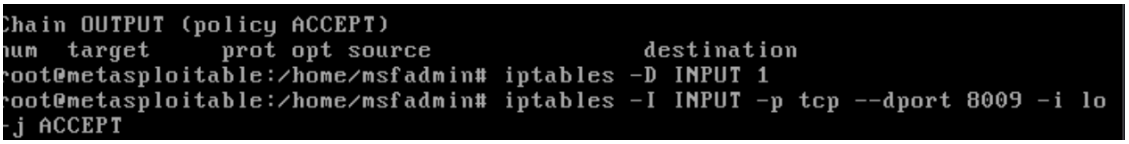


Figura 22 – Eliminazione della regola sbagliata (-D INPUT 1) e nuovo inserimento con la porta 8009

`iptables -L -n -v --line-numbers` mostra lo stato finale della catena INPUT.

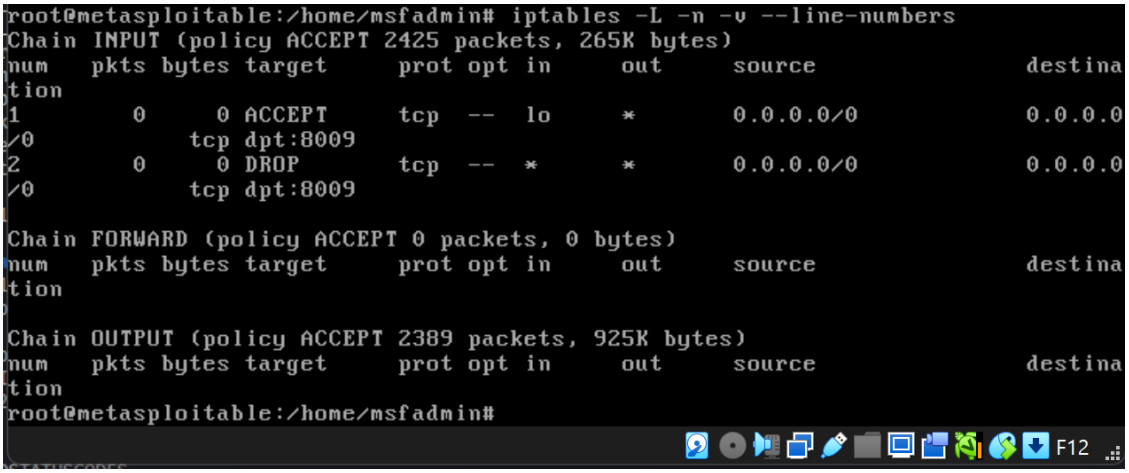


Figura 23 – Stato finale: ACCEPT per l'interfaccia lo e DROP per tutto il resto, entrambi sulla porta 8009

La catena INPUT contiene ora due regole sulla porta 8009: la numero 1 accetta il traffico locale (interfaccia lo) e la numero 2 scarta tutto il resto. Il controllo del loopback viene valutato per primo, quindi le comunicazioni interne continuano a funzionare.

6.3 Verifica

`nmap -sV -p 8009 192.168.51.101` e `nc -zv -w 3 192.168.51.101 8009`

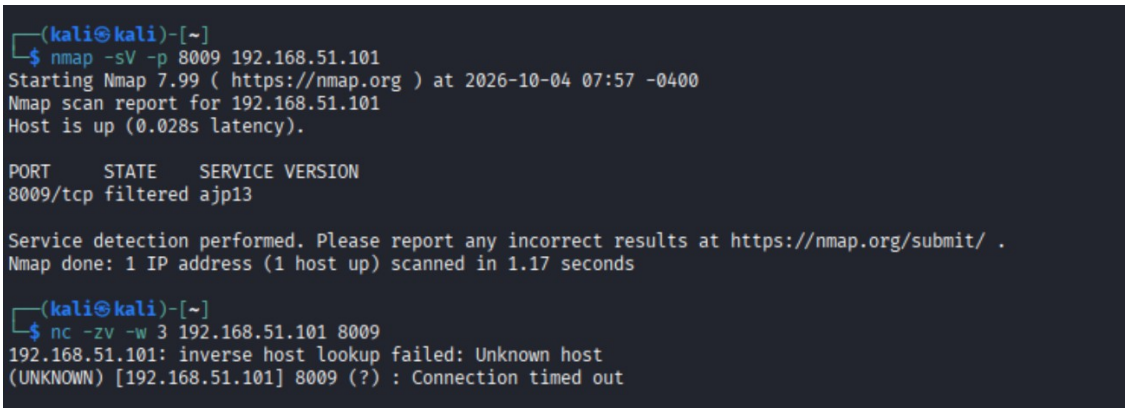


Figura 24 – La porta 8009 passa da open a filtered e la connessione va in timeout

Nella scansione iniziale la porta 8009 risultava aperta e riconosciuta come ajp13 (Apache Jserv). Ora nmap la segnala come filtered e non riesce più nemmeno a identificare la versione del servizio. Il test con netcat termina con "Connection timed out", cioè nessuna risposta: è il comportamento tipico di una regola DROP.

Nota. Si tratta di una mitigazione, non di una correzione: Apache Tomcat resta una versione obsoleta e vulnerabile, ma il connettore AJP non è più raggiungibile dalla rete. La regola agisce sul firewall in esecuzione: per mantenerla dopo un riavvio va salvata con iptables-save e ripristinata all'avvio. La soluzione definitiva è aggiornare Tomcat (7.0.100, 8.5.51, 9.0.31 o successivi, come indica Nessus) oppure disabilitare il connettore AJP.

7. Verifica complessiva prima e dopo

A interventi terminati è stata ripetuta la stessa scansione nmap eseguita all'inizio, con lo stesso comando e sulla stessa macchina.

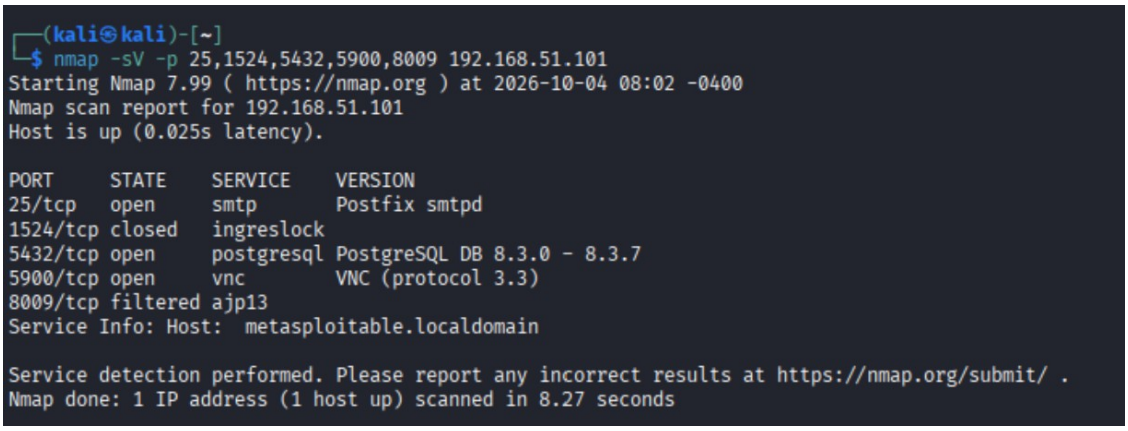


Figura 25 – Scansione nmap finale (4 ottobre 2026, 08:02), da confrontare con la Figura 1

Porta	Prima (05:16)	Dopo (08:02)
25/tcp	Aperta: Postfix, SSLv2/SSLv3 attivi	Aperta: Postfix, nessuna cifratura offerta
1524/tcp	Aperta: shell root senza autenticazione	Chiusa
5432/tcp	Aperta: PostgreSQL, SSLv3 attivo	Aperta: PostgreSQL, SSL disattivato
5900/tcp	Aperta: VNC con password "password"	Aperta: VNC con nuova password

Porta	Prima (05:16)	Dopo (08:02)
8009/tcp	Aperta: AJP (ajp13)	Filtrata dal firewall

Le porte 25, 5432 e 5900 restano aperte perché i servizi continuano a funzionare: è cambiata la loro configurazione, e questo nmap da solo non lo mostra. Le prove sono i test mirati descritti nei capitoli precedenti (nmap con gli script SSL, comando EHLO, accesso VNC con le due password). Le due porte che cambiano stato sono la 1524, ora chiusa, e la 8009, ora filtrata.

8. Vulnerabilità critiche non risolte e soluzione teorica

8.1 Canonical Ubuntu Linux SEOL (8.04.x)

Il sistema operativo è Ubuntu 8.04, giunto a fine supporto da molti anni: non riceve più aggiornamenti di sicurezza, quindi ogni vulnerabilità scoperta nel kernel e nei pacchetti resta aperta in modo permanente. La soluzione corretta è migrare a una release supportata di Ubuntu LTS. Da una versione così vecchia un aggiornamento sul posto, passando per tutte le release intermedie, è poco praticabile perché i repository originali non sono più mantenuti. Si consiglia una nuova installazione di una LTS supportata, con migrazione di dati e configurazioni e riconfigurazione dei servizi. Nell'attesa si possono adottare misure compensative: isolare la macchina in un segmento di rete dedicato, limitare i servizi esposti con il firewall, disattivare i servizi non necessari e monitorare gli accessi. In questo esercizio la vulnerabilità non è stata risolta e resterà visibile nella scansione finale.

8.2 Apache Tomcat SEOL e Debian OpenSSH/OpenSSL

Anche queste due criticità dipendono dall'obsolescenza dei componenti. Apache Tomcat <= 5.5.x non è più supportato e va aggiornato a una versione mantenuta. Il difetto del generatore di numeri casuali di Debian OpenSSH/OpenSSL produce chiavi prevedibili: si risolve aggiornando i pacchetti e rigenerando tutte le chiavi e i certificati interessati, come le chiavi host SSH e i certificati SSL. Non sono state selezionate per questo esercizio.

9. Conclusioni

Le quattro vulnerabilità critiche selezionate sono state trattate con azioni mirate e verificate con prove prima e dopo: la backdoor sulla porta 1524 è stata disattivata, la password VNC debole è stata sostituita, i protocolli SSLv2 e SSLv3 non sono più offerti da Postfix e PostgreSQL, e l'accesso al connettore AJP sulla porta 8009 è stato bloccato con una regola iptables. Per alcune azioni (SSL e Ghostcat) si tratta di mitigazioni dovute all'obsolescenza del software: la soluzione definitiva resta l'aggiornamento del sistema e dei servizi. Il Report 3 (ScansioneFine) mostrerà la scansione Nessus eseguita dopo le modifiche, con la stessa policy della scansione iniziale, per confrontare i risultati.